

Securing Apache Kafka

- Broker support multiple ports
 - plain text (no wire encryption/authentication)
 - SSL (for wire encryption/authentication)
 - SASL (for Kerberos authentication)
 - SSL + SASL (SSL for wire encryption, SASL for authentication)
- Clients choose which port to use
 - need to provide required credentials through configs

- **r3.xlarge**
 - **4 core, 30GB ram, 80GB ssd, moderate network (~90MB/s)**

	Throughput(MB/S)	CPU on client	CPU on broker
Producer(plaintext)	83	12%	30%
Producer (SSL)	69	28%	48%
Consumer (plaintext)	83	8%	2%
Consumer (SSL)	69	27%	24%

- **Most overhead from encryption**

- No client code change; just configuration change.

Client/Broker

```
ssl.keystore.location =  
/var/private/ssl/kafka.server.keystore.jks  
ssl.keystore.password = test1234  
ssl.key.password = test1234  
ssl.truststore.location =  
/var/private/ssl/kafka.server.truststore.jks  
ssl.truststore.password = test1234
```

Broker

```
listeners = SSL://host.name:port  
security.inter.broker.protocol = SSL  
ssl.client.auth = required
```

Client

```
security.protocol = SSL
```

Configuring Kerberos

Tos

No client code change; just configuration change

Broker JAAS file

```
KafkaServer {  
    com.sun.security.auth.module.  
    Krb5LoginModule required  
    useKeyTab=true  
    storeKey=true  
    keyTab="/etc/security/keyt  
    abs/kafka_server.keytab"  
    principal="kafka/kafka1.ho  
    stname.com@EXAMPLE.COM";  
};
```

Client JAAS file

```
KafkaClient {  
    com.sun.security.auth.module.  
    Krb5LoginModule required  
    useKeyTab=true  
    storeKey=true  
    keyTab="/etc/security/keyt  
    abs/kafka_client.keytab"  
    principal="kafka-client-  
    1@EXAMPLE.COM";  
};
```

Broker JVM

```
Djava.security.auth.lo  
gin.config=/etc/kafka/  
kafka_server_jaas.conf
```

Client JVM

```
-  
Djava.security.auth.log  
in.config=/etc/kafka/  
kafka_client_jaas.conf
```

Broker config

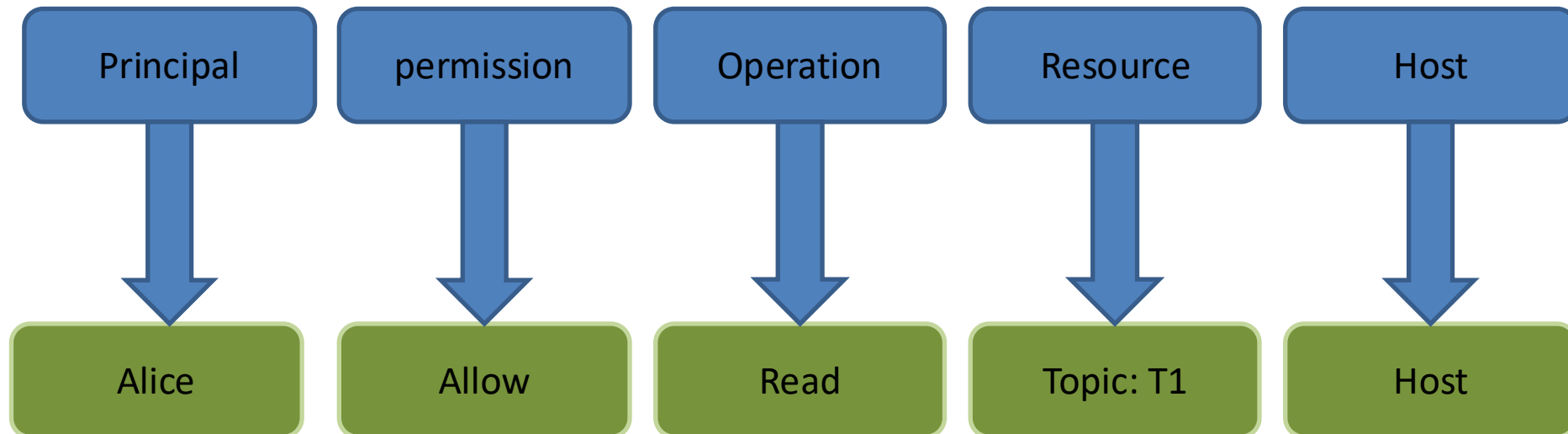
```
# List of enabled mechanisms, can be more than one  
sasl.enabled.mechanisms=PLAIN  
# Specify one of the SASL mechanisms  
sasl.mechanism.inter.broker.protocol=PLAIN
```

Client config

```
# List of enabled mechanisms, can be more than one  
sasl.enabled.mechanisms=PLAIN  
# Specify one of the SASL mechanisms  
sasl.mechanism.inter.broker.protocol=PLAIN
```

- Authentication (SSL or SASL) happens once during socket connection
 - No re-authentication
- If a certificate needs to be revoked, use authorization to remove permission

Alice is Allowed to Read from topic T1 from Host1



- Operations
 - Read, Write, Create, Describe, ClusterAction, All
- Resources
 - Topic, Cluster and ConsumerGroup

Operations	Resources
Read, write, Describe (Read, Write implies Describe)	Topic
Read	Consumer Group
Create, ClusterAction(communication between controller and brokers)	Cluster

- `authorizer.class.name=kafka.security.auth.SimpleAclAuthorizer`
- Make Kafka principal super users
 - Or grant ClusterAction and Read all topics to Kafka principal

- Producer
 - Grant Write on topic, Create on cluster (auto creation)
 - Or use --producer option in CLI

`/opt/kafka/bin/kafka-acls.sh --bootstrap-server kafka0:9092 --command-config admin.properties --add --allow-principal User:alice --operation All --topic plain-topic`

```
[root@kafka0 config]# cd /opt/scripts
[root@kafka0 scripts]# /opt/kafka/bin/kafka-acls.sh --bootstrap-server localhost:9092 --command-config admin.properties --add --allow-principal User:alice --operation All --topic plain-topic
Adding ACLs for resource `ResourcePattern(resourceType=TOPIC, name=plain-topic, patternType=LITERAL)`:
    (principal=User:alice, host=*, operation=ALL, permissionType=ALLOW)

Current ACLs for resource `ResourcePattern(resourceType=TOPIC, name=plain-topic, patternType=LITERAL)`:
    (principal=User:alice, host=*, operation=WRITE, permissionType=ALLOW)
    (principal=User:alice, host=*, operation=ALL, permissionType=ALLOW)

[root@kafka0 scripts]# █
```

- Consumer
 - Grant Read on topic, Read on consumer group
 - Or use --consumer option in CLI

`/opt/kafka/bin/kafka-acls.sh --bootstrap-server=kafka0:9092 -command-config admin.properties --add --allow-principal User:bob --operation Read --topic plain-topic`

```
[root@kafka0 scripts]# /opt/kafka/bin/kafka-acls.sh --bootstrap-server=localhost:9092 -command-config admin.properties --add --allow-principal User:bob --operation Read --topic plain-topic
Adding ACLs for resource `ResourcePattern(resourceType=TOPIC, name=plain-topic, patternType=LITERAL)`:
    (principal=User:bob, host=*, operation=READ, permissionType=ALLOW)

Current ACLs for resource `ResourcePattern(resourceType=TOPIC, name=plain-topic, patternType=LITERAL)`:
    (principal=User:bob, host=*, operation=READ, permissionType=ALLOW)
    (principal=User:alice, host=*, operation=WRITE, permissionType=ALLOW)
    (principal=User:alice, host=*, operation=ALL, permissionType=ALLOW)

[root@kafka0 scripts]#
```

Lab : -

Securing Kafka SSL – 90 Minutes

Securing Kafka ACL – 60 Minutes